

# SOC 2 Type II Evidence Automation

DevOps.ai

January 2025

## Contents

|          |                                                                                     |          |
|----------|-------------------------------------------------------------------------------------|----------|
| <b>1</b> | <b>SOC 2 Type II Evidence Automation</b>                                            | <b>1</b> |
| 1.1      | Complete Guide to Automating SOC 2 Type II Compliance Evidence Collection . . . . . | 1        |
| 1.2      | Executive Summary . . . . .                                                         | 1        |
| 1.3      | Table of Contents . . . . .                                                         | 2        |
| 1.4      | 1. SOC 2 Type II Fundamentals . . . . .                                             | 2        |
| 1.5      | 2. Trust Services Criteria Mapping . . . . .                                        | 3        |
| 1.6      | 3. Evidence Requirements by Control . . . . .                                       | 5        |
| 1.7      | 4. Automation Architecture . . . . .                                                | 10       |
| 1.8      | 5. Evidence Collection Strategies . . . . .                                         | 13       |
| 1.9      | 6. Continuous Monitoring . . . . .                                                  | 14       |
| 1.10     | 7. Audit Preparation . . . . .                                                      | 15       |
| 1.11     | 8. Common Pitfalls . . . . .                                                        | 16       |
| 1.12     | 9. Implementation Roadmap . . . . .                                                 | 17       |

## 1 SOC 2 Type II Evidence Automation

### 1.1 Complete Guide to Automating SOC 2 Type II Compliance Evidence Collection

Version 1.0 | January 2025 | DevOps.ai

---

### 1.2 Executive Summary

SOC 2 Type II audits require continuous evidence collection over 6-12 months, demonstrating that security controls operate effectively over time. Manual evidence collection consumes 200-400 hours per audit cycle, with significant risk of gaps, inconsistencies, and last-minute scrambles.

This whitepaper provides a complete guide to automating SOC 2 Type II evidence collection using AlDeci, covering all five Trust Services Criteria (Security, Availability, Processing Integrity, Confidentiality, Privacy), evidence mapping, automation strategies, and audit preparation.

**Key Benefits:** - Reduce audit prep time by 80% (from 400 hours to 80 hours) - Eliminate evidence gaps with continuous automated collection - Generate cryptographically signed, tamper-proof evidence bundles - Maintain 7-year evidence retention for regulatory compliance - Achieve audit-ready status in 2 days instead of 2 months

---

## 1.3 Table of Contents

1. SOC 2 Type II Fundamentals
  2. Trust Services Criteria Mapping
  3. Evidence Requirements by Control
  4. Automation Architecture
  5. Evidence Collection Strategies
  6. Continuous Monitoring
  7. Audit Preparation
  8. Common Pitfalls
  9. Implementation Roadmap
- 

## 1.4 1. SOC 2 Type II Fundamentals

### 1.4.1 1.1 SOC 2 Overview

**SOC 2 (Service Organization Control 2)** is an auditing standard developed by the American Institute of CPAs (AICPA) for service providers storing customer data in the cloud. SOC 2 reports demonstrate that an organization has appropriate controls in place to protect customer data.

#### Two Report Types:

**Type I:** Point-in-time assessment - Evaluates control design at a specific date - Faster and less expensive - Does not prove operational effectiveness

**Type II:** Period-of-time assessment - Evaluates control design AND operational effectiveness over 6-12 months - More comprehensive and credible - Required by most enterprise customers - **This whitepaper focuses on Type II**

### 1.4.2 1.2 Trust Services Criteria

SOC 2 is based on five Trust Services Criteria (TSC):

**1. Security (CC - Common Criteria)** - Required for all SOC 2 audits - Covers access controls, encryption, vulnerability management, incident response - 17 control points (CC1.1 - CC9.2)

**2. Availability** - Optional (selected based on business needs) - Covers system uptime, disaster recovery, capacity planning - 3 control points (A1.1 - A1.3)

**3. Processing Integrity** - Optional - Covers data processing accuracy, completeness, timeliness - 3 control points (PI1.1 - PI1.5)

**4. Confidentiality** - Optional - Covers protection of confidential information - 2 control points (C1.1 - C1.2)

**5. Privacy** - Optional - Covers personal information handling (GDPR, CCPA compliance) - 9 control points (P1.1 - P8.1)

**Most Common Combination:** Security + Availability (covers 95% of customer requirements)

### 1.4.3 1.3 Type II Evidence Requirements

**Type I Evidence** (point-in-time): - Policy documents - System configurations - Access control lists - Single vulnerability scan report

**Type II Evidence** (continuous): - **Weekly vulnerability scans** (52 reports over 12 months) - **Monthly access reviews** (12 reports) - **Quarterly penetration tests** (4 reports) - **Daily backup logs** (365 logs) - **Continuous monitoring dashboards** - **Incident response records** (all incidents during audit period) - **Change management tickets** (all changes during audit period)

**Challenge:** Collecting and organizing 500+ evidence artifacts over 12 months

---

## 1.5 2. Trust Services Criteria Mapping

### 1.5.1 2.1 Security (Common Criteria)

| Control                               | Description                      | Evidence Type                         | AI/Deci Automation |
|---------------------------------------|----------------------------------|---------------------------------------|--------------------|
| <b>CC1.1</b>                          | CISO designated                  | Org chart, job description            | Manual (one-time)  |
| <b>CC1.2</b>                          | Board oversight                  | Board meeting minutes                 | Manual (quarterly) |
| <b>CC1.3</b>                          | Organizational structure         | Org chart, reporting lines            | Manual (annual)    |
| <b>CC1.4</b> Commitment to competence | Training records, certifications | Semi-automated                        |                    |
| <b>CC1.5</b>                          | Accountability                   | Performance reviews                   | Manual (annual)    |
| <b>CC2.1</b>                          | Risk assessment                  | Risk register, threat model           | Automated          |
| <b>CC2.2</b>                          | Risk mitigation                  | Remediation tickets, evidence bundles | Automated          |
| <b>CC2.3</b>                          | Vendor risk                      | Vendor assessments, SLAs              | Semi-automated     |
| <b>CC3.1</b>                          | Security policies                | Policy documents, version control     | Manual (annual)    |

| Control      | Description              | Evidence Type                                   | AIDeci Automation      |
|--------------|--------------------------|-------------------------------------------------|------------------------|
| <b>CC3.2</b> | Policy communication     | Training completion, acknowledgments            | Semi-automated         |
| <b>CC3.3</b> | Policy enforcement       | Audit logs, violations                          | Automated              |
| <b>CC3.4</b> | Policy review            | Policy review records                           | Manual (annual)        |
| <b>CC4.1</b> | Monitoring activities    | SIEM logs, alerts                               | Automated              |
| <b>CC4.2</b> | Incident detection       | IDS/IPS logs, SIEM alerts                       | Automated              |
| <b>CC5.1</b> | Control activities       | Control test results                            | Automated              |
| <b>CC5.2</b> | Control monitoring       | Control effectiveness reports                   | Automated              |
| <b>CC5.3</b> | Endpoint security        | EDR logs, patch status                          | Automated              |
| <b>CC6.1</b> | Logical access           | Access control lists, IAM logs                  | Automated              |
| <b>CC6.2</b> | Access reviews           | Quarterly access reviews                        | Semi-automated         |
| <b>CC6.3</b> | Access removal           | Offboarding tickets, access revocation logs     | Automated              |
| <b>CC6.4</b> | Privileged access        | Privileged access logs, MFA logs                | Automated              |
| <b>CC6.5</b> | Access provisioning      | Onboarding tickets, access requests             | Semi-automated         |
| <b>CC6.6</b> | Encryption               | Encryption status, key management logs          | Automated              |
| <b>CC6.7</b> | Transmission security    | TLS configuration, certificate status           | Automated              |
| <b>CC6.8</b> | Data classification      | Data classification tags, DLP logs              | Semi-automated         |
| <b>CC7.1</b> | Vulnerability management | Vulnerability scan reports, remediation tickets | <b>Fully Automated</b> |
| <b>CC7.2</b> | Patch management         | Patch status reports, deployment logs           | <b>Fully Automated</b> |
| <b>CC7.3</b> | Malware protection       | Antivirus logs, malware detections              | Automated              |
| <b>CC7.4</b> | Network security         | Firewall rules, network segmentation            | Automated              |

| Control      | Description         | Evidence Type                               | AlDeci Automation      |
|--------------|---------------------|---------------------------------------------|------------------------|
| <b>CC7.5</b> | Security testing    | Penetration test reports, SAST/DAST results | <b>Fully Automated</b> |
| <b>CC8.1</b> | Change management   | Change tickets, approval records            | Semi-automated         |
| <b>CC9.1</b> | Incident response   | Incident tickets, response timelines        | Semi-automated         |
| <b>CC9.2</b> | Business continuity | DR test results, backup logs                | Automated              |

**AlDeci Coverage:** 22 of 34 controls (65%) fully or semi-automated

### 1.5.2 2.2 Availability

| Control     | Description              | Evidence Type                    | AlDeci Automation |
|-------------|--------------------------|----------------------------------|-------------------|
| <b>A1.1</b> | Availability commitments | SLA documents, uptime reports    | Automated         |
| <b>A1.2</b> | System monitoring        | Uptime monitoring, alerting logs | Automated         |
| <b>A1.3</b> | Incident response        | Incident tickets, MTTR reports   | Semi-automated    |

**AlDeci Coverage:** 3 of 3 controls (100%) fully or semi-automated

### 1.5.3 2.3 Processing Integrity

| Control      | Description           | Evidence Type                  | AlDeci Automation |
|--------------|-----------------------|--------------------------------|-------------------|
| <b>PI1.1</b> | Processing objectives | Process documentation          | Manual            |
| <b>PI1.2</b> | Data validation       | Validation logs, error rates   | Automated         |
| <b>PI1.3</b> | Error handling        | Error logs, exception handling | Automated         |
| <b>PI1.4</b> | Processing monitoring | Processing metrics, dashboards | Automated         |
| <b>PI1.5</b> | Processing controls   | Control test results           | Automated         |

**AlDeci Coverage:** 4 of 5 controls (80%) automated

## 1.6 3. Evidence Requirements by Control

### 1.6.1 3.1 CC7.1: Vulnerability Management

**Control Objective:** Identify and remediate vulnerabilities in a timely manner

**Evidence Requirements:** 1. **Weekly vulnerability scans** (52 reports) - All production systems - All development systems - All cloud infrastructure

## 2. **Vulnerability remediation tickets** (all critical/high findings)

- Ticket creation date
- Ticket resolution date
- MTTR calculation

## 3. **Risk-based prioritization** (evidence of risk scoring)

- CVSS scores
- EPSS scores
- KEV flags
- FixOpsRisk scores

## 4. **Remediation evidence** (proof of fix)

- Post-remediation scans
- Version upgrades
- Patch deployments

### **AlDeci Automation:**

```
# Weekly vulnerability scan evidence bundle
evidence_bundle:
  type: vulnerability_scan
  frequency: weekly
  contents:
    - normalized_sbom.json
    - vulnerability_report.json
    - risk_scoring_report.json
    - remediation_tickets.json
    - epss_kev_enrichment.json
  signature: RSA-SHA256
  retention: 7_years
```

### **Audit Artifact:**

SOC2-CC7.1-Vulnerability-Management-2024-Q4.pdf

#### Executive Summary

Total vulnerabilities: 1,247  
Critical (FixOpsRisk 85): 18  
High (FixOpsRisk 60-84): 142  
Average MTTR (critical): 7 days  
SLA compliance: 98.2%

#### Weekly Scan Reports (13 weeks)

Week 1: 2024-10-01  
Week 2: 2024-10-08  
...

#### Remediation Evidence

CVE-2024-1234: Remediated 2024-10-05  
CVE-2024-5678: Remediated 2024-10-12  
...

#### Cryptographic Signature

RSA-SHA256: a1b2c3d4...

## 1.6.2 3.2 CC7.2: Patch Management

**Control Objective:** Apply security patches in a timely manner

**Evidence Requirements:** 1. **Monthly patch status reports** (12 reports) - All systems - Patch compliance percentage - Overdue patches

2. **Patch deployment logs** (all patches)
  - Patch ID
  - Deployment date
  - Success/failure status
3. **Version lag tracking** (evidence of currency)
  - Current versions
  - Latest versions
  - Days behind latest
4. **Exception approvals** (for delayed patches)
  - Risk acceptance forms
  - Compensating controls
  - Remediation timeline

### AlDeci Automation:

```
# Monthly patch management evidence bundle
evidence_bundle:
  type: patch_management
  frequency: monthly
  contents:
    - patch_status_report.json
    - version_lag_analysis.json
    - patch_deployment_logs.json
    - exception_approvals.json
  signature: RSA-SHA256
  retention: 7_years
```

### Audit Artifact:

SOC2-CC7.2-Patch-Management-2024-Q4.pdf

Executive Summary

Total systems: 487

Patch compliance: 94.2%

Average version lag: 12 days

Overdue patches: 28

Monthly Reports (3 months)

October 2024

November 2024

December 2024

Deployment Evidence

Patch KB5012345: Deployed 2024-10-15

Patch KB5012346: Deployed 2024-10-22

...

Exception Approvals

System XYZ: Patch delayed due to compatibility  
Compensating control: Network segmentation

### 1.6.3 3.3 CC7.5: Security Testing

**Control Objective:** Perform regular security testing (SAST, DAST, SCA, penetration testing)

**Evidence Requirements:** 1. **Quarterly penetration tests** (4 reports) - External penetration test - Internal penetration test - Findings and remediation

2. **Weekly SAST scans** (52 reports)

- All code repositories
- Critical/high findings
- Remediation evidence

3. **Weekly DAST scans** (52 reports)

- All production applications
- OWASP Top 10 coverage
- Remediation evidence

4. **Weekly SCA scans** (52 reports)

- All dependencies
- Vulnerable components
- Remediation evidence

#### AlDeci Automation:

```
# Weekly security testing evidence bundle
evidence_bundle:
  type: security_testing
  frequency: weekly
  contents:
    - sast_report.sarif
    - dast_report.sarif
    - sca_report.sarif
    - unified_findings.json
    - remediation_tickets.json
  signature: RSA-SHA256
  retention: 7_years
```

#### Audit Artifact:

SOC2-CC7.5-Security-Testing-2024-Q4.pdf

Executive Summary

SAST scans: 13 (weekly)

DAST scans: 13 (weekly)

SCA scans: 13 (weekly)

Penetration tests: 1 (quarterly)

Total findings: 847

SAST Results

Critical: 5



High: 42  
Remediation rate: 96%  
DAST Results  
Critical: 2  
High: 18  
Remediation rate: 98%  
SCA Results  
Critical: 18  
High: 142  
Remediation rate: 94%  
Penetration Test  
Date: 2024-12-15  
Findings: 12  
Remediation: 100%

#### 1.6.4 3.4 CC6.1: Logical Access Controls

**Control Objective:** Restrict logical access to authorized users

**Evidence Requirements:** 1. **Quarterly access reviews** (4 reports) - All user accounts - Access rights verification - Inappropriate access removal

2. **Daily access logs** (365 logs)
  - Login attempts
  - Failed authentications
  - Privileged access usage
3. **MFA enforcement** (continuous)
  - MFA enrollment status
  - MFA authentication logs
  - MFA bypass exceptions
4. **Offboarding evidence** (all terminated users)
  - Termination date
  - Access revocation date
  - Account deletion confirmation

#### AlDeci Automation:

```
# Quarterly access review evidence bundle
evidence_bundle:
  type: access_review
  frequency: quarterly
  contents:
    - user_access_list.json
    - access_review_results.json
    - inappropriate_access_removals.json
    - mfa_status_report.json
  signature: RSA-SHA256
  retention: 7_years
```

## 1.7 4. Automation Architecture

### 1.7.1 4.1 Evidence Collection Pipeline

#### Evidence Sources

|                     |                 |                  |                         |
|---------------------|-----------------|------------------|-------------------------|
| Scanners<br>(SARIF) | CI/CD<br>(Logs) | SIEM<br>(Alerts) | Cloud APIs<br>(Configs) |
|---------------------|-----------------|------------------|-------------------------|

#### AlDeci

- Normalize
- Correlate
- Enrich
- Sign
- Store

#### Evidence Store

- 7-year retention
- Encrypted
- Tamper-proof
- Audit-ready

#### Audit Reports

- SOC 2 mapping
- Evidence bundles
- Signed PDFs

### 1.7.2 4.2 Evidence Bundle Structure

#### Bundle Contents:

```
{
  "bundle_id": "SOC2-CC7.1-2024-W42",
  "control": "CC7.1",
  "control_name": "Vulnerability Management",
  "period": "2024-10-14 to 2024-10-20",
  "evidence_type": "vulnerability_scan",
  "artifacts": [
    {
```

```

    "type": "sbom",
    "format": "CycloneDX",
    "file": "sbom.json",
    "hash": "sha256:a1b2c3d4..."
  },
  {
    "type": "vulnerability_report",
    "format": "JSON",
    "file": "vulnerabilities.json",
    "hash": "sha256:e5f6g7h8..."
  },
  {
    "type": "risk_scoring",
    "format": "JSON",
    "file": "risk_scores.json",
    "hash": "sha256:i9j0k1l2..."
  },
  {
    "type": "remediation_tickets",
    "format": "JSON",
    "file": "tickets.json",
    "hash": "sha256:m3n4o5p6..."
  }
],
"signature": {
  "algorithm": "RSA-SHA256",
  "public_key": "-----BEGIN PUBLIC KEY-----...",
  "signature": "q7r8s9t0u1v2w3x4y5z6..."
},
"metadata": {
  "generated_at": "2024-10-20T23:59:59Z",
  "generated_by": "AlDeci v1.2.3",
  "organization": "Example Corp",
  "auditor": "Big Four Audit Firm"
}
}

```

### 1.7.3 4.3 Continuous Evidence Collection

#### GitHub Actions Example:

```

# .github/workflows/soc2-evidence.yml
name: SOC 2 Evidence Collection

on:
  schedule:
    - cron: '0 0 * * 0' # Weekly on Sunday

```

```

workflow_dispatch:

jobs:
  collect-evidence:
    runs-on: ubuntu-latest
    steps:
      - uses: actions/checkout@v3

      - name: Generate SBOM
        run: syft . -o cyclonedx-json > sbom.json

      - name: Run vulnerability scan
        run: grype sbom:sbom.json -o json > vulnerabilities.json

      - name: Run SAST scan
        run: semgrep --config=auto --sarif > sast.sarif

      - name: Run SCA scan
        run: snyk test --sarif > sca.sarif

      - name: Push evidence to AlDeci
        run: |
          curl -X POST https://api.devops.ai/products/aldeci/evidence/soc2 \
            -H "Authorization: Bearer ${ secrets.ALDECI_TOKEN }" \
            -F "control=CC7.1" \
            -F "sbom=@sbom.json" \
            -F "vulnerabilities=@vulnerabilities.json" \
            -F "sast=@sast.sarif" \
            -F "sca=@sca.sarif"

      - name: Generate evidence bundle
        run: |
          curl -X POST https://api.devops.ai/products/aldeci/evidence/bundle \
            -H "Authorization: Bearer ${ secrets.ALDECI_TOKEN }" \
            -d '{"control": "CC7.1", "period": "weekly"}' \
            -o evidence-bundle.zip

      - name: Upload evidence bundle
        uses: actions/upload-artifact@v3
        with:
          name: soc2-evidence
          path: evidence-bundle.zip
          retention-days: 2555 # 7 years

```

## 1.8 5. Evidence Collection Strategies

### 1.8.1 5.1 Strategy 1: Push-Based Collection

**Description:** Applications push evidence to AlDeci during CI/CD

**Pros:** - Real-time evidence collection - No polling or scheduled jobs - Minimal infrastructure

**Cons:** - Requires CI/CD integration - May slow down pipelines

**Implementation:**

```
# In CI/CD pipeline
aldecide evidence push \
  --control CC7.1 \
  --type vulnerability_scan \
  --file vulnerabilities.json
```

### 1.8.2 5.2 Strategy 2: Pull-Based Collection

**Description:** AlDeci pulls evidence from scanners/tools via APIs

**Pros:** - No CI/CD changes required - Centralized collection - Works with legacy systems

**Cons:** - Requires API access to all tools - Potential delays in evidence collection - Additional infrastructure

**Implementation:**

```
# AlDeci configuration
evidence_sources:
  - type: snyk
    api_endpoint: https://api.snyk.io
    api_token: ${SNYK_TOKEN}
    collection_frequency: daily
    controls: [CC7.1, CC7.5]

  - type: sonarqube
    api_endpoint: https://sonarqube.example.com
    api_token: ${SONAR_TOKEN}
    collection_frequency: weekly
    controls: [CC7.5]
```

### 1.8.3 5.3 Strategy 3: Hybrid Collection

**Description:** Combine push and pull based on evidence type

**Pros:** - Flexibility - Optimal for each evidence type - Best of both worlds

**Cons:** - More complex configuration - Requires both push and pull infrastructure

**Recommendation:** Use hybrid approach - **Push:** CI/CD evidence (SBOM, SARIF, build logs) - **Pull:** Infrastructure evidence (cloud configs, access logs, SIEM alerts)

---

## 1.9 6. Continuous Monitoring

### 1.9.1 6.1 Real-Time Dashboards

AlDeci provides real-time SOC 2 compliance dashboards:

**Dashboard Widgets:** 1. **Control Coverage:** % of controls with evidence 2. **Evidence Gaps:** Controls missing evidence 3. **Remediation Status:** Open vs. closed findings 4. **MTTR Trends:** Average time to remediate 5. **SLA Compliance:** % of findings remediated within SLA 6. **Audit Readiness:** Days until audit-ready

#### Example Dashboard:

##### SOC 2 Compliance Dashboard

Control Coverage: 94% (32/34 controls)  
Evidence Gaps: 2 (CC1.2, CC1.5)  
Open Findings: 18 critical, 142 high  
Average MTTR: 7 days (critical), 21 days (high)  
SLA Compliance: 98.2%  
Audit Readiness: READY (2 days to generate reports)

### 1.9.2 6.2 Alerting and Notifications

AlDeci sends alerts for compliance issues:

**Alert Types:** 1. **Evidence Gap:** Control missing evidence for > 7 days 2. **SLA Breach:** Finding not remediated within SLA 3. **Control Failure:** Control test failed 4. **Audit Deadline:** Audit approaching (30/60/90 days)

#### Example Alert:

Subject: [AlDeci] Evidence Gap Alert - CC7.1

Control: CC7.1 (Vulnerability Management)  
Issue: No vulnerability scan evidence for 8 days  
Last Evidence: 2024-10-12  
Expected Frequency: Weekly  
Action Required: Run vulnerability scan and push evidence to AlDeci

Run: aldecide evidence push --control CC7.1 --file vulnerabilities.json

---

## 1.10 7. Audit Preparation

### 1.10.1 7.1 Evidence Package Generation

AlDeci generates audit-ready evidence packages:

**Command:**

```
aldeci audit prepare \  
  --framework SOC2 \  
  --type Type-II \  
  --period "2024-01-01 to 2024-12-31" \  
  --output soc2-evidence-package.zip
```

**Package Contents:**

```
soc2-evidence-package.zip  
  00-Executive-Summary.pdf  
  01-Control-Matrix.xlsx  
  02-Evidence-Index.xlsx  
  03-Security-CC/  
    CC1.1-CIS0-Designation.pdf  
    CC1.2-Board-Oversight.pdf  
    CC7.1-Vulnerability-Management/  
      2024-Q1-Vulnerability-Scans.pdf  
      2024-Q2-Vulnerability-Scans.pdf  
      2024-Q3-Vulnerability-Scans.pdf  
      2024-Q4-Vulnerability-Scans.pdf  
      Remediation-Evidence.pdf  
    CC7.2-Patch-Management/  
      2024-01-Patch-Status.pdf  
      2024-02-Patch-Status.pdf  
      ...  
    CC7.5-Security-Testing/  
      2024-Q1-Penetration-Test.pdf  
      2024-Q2-Penetration-Test.pdf  
      SAST-Results-2024.pdf  
      DAST-Results-2024.pdf  
      SCA-Results-2024.pdf  
  04-Availability-A/  
    A1.1-Uptime-Reports.pdf  
    A1.2-Monitoring-Evidence.pdf  
  99-Signatures/  
    evidence-signatures.json  
    public-key.pem
```

### 1.10.2 7.2 Auditor Portal

AlDeci provides a secure portal for auditors:

**Portal Features:** 1. **Evidence Browser:** Search and filter evidence 2. **Control Matrix:** View control coverage 3. **Evidence Verification:** Verify cryptographic signatures 4. **Export:** Download evidence packages 5. **Audit Trail:** View evidence collection timeline

**Access:**

```
# Generate auditor access token (expires in 90 days)
aldec audit grant-access \
  --auditor "Big Four Audit Firm" \
  --email auditor@bigfour.com \
  --expires 90d

# Auditor receives secure link
https://audit.devops.ai/portal?token=abc123...
```

---

## 1.11 8. Common Pitfalls

### 1.11.1 8.1 Pitfall 1: Evidence Gaps

**Problem:** Missing evidence for specific weeks/months

**Example:** Vulnerability scans for weeks 15-18 missing due to CI/CD outage

**Impact:** Auditor cannot verify continuous operation of control

**Solution:** - Implement backup evidence collection (manual scans during outages) - Monitor evidence collection with alerts - Maintain evidence collection SLA (99.5% uptime)

### 1.11.2 8.2 Pitfall 2: Inconsistent Evidence Format

**Problem:** Evidence format changes over time

**Example:** Q1 vulnerability scans in CSV, Q2-Q4 in JSON

**Impact:** Difficult to correlate and analyze evidence

**Solution:** - Standardize on SARIF for security findings - Standardize on CycloneDX for SBOMs - Use AlDeci normalization to convert legacy formats

### 1.11.3 8.3 Pitfall 3: Unsigned Evidence

**Problem:** Evidence not cryptographically signed

**Example:** Auditor questions evidence authenticity

**Impact:** Evidence may be rejected, requiring re-collection

**Solution:** - Sign all evidence bundles with RSA-SHA256 or Cosign - Maintain key management procedures - Provide public key to auditor for verification



#### 1.11.4 8.4 Pitfall 4: Insufficient Retention

**Problem:** Evidence deleted before audit

**Example:** Evidence retention set to 90 days, audit delayed to 180 days

**Impact:** Evidence unavailable for audit

**Solution:** - Set retention to 7 years (regulatory requirement) - Implement tiered storage (hot/warm/cold) - Monitor storage capacity and costs

---

### 1.12 9. Implementation Roadmap

#### 1.12.1 9.1 Phase 1: Foundation (Weeks 1-4)

**Week 1-2: Assessment** - Identify SOC 2 controls in scope - Map controls to evidence requirements - Identify evidence sources (scanners, tools, logs) - Document current evidence collection process

**Week 3-4: AlDeci Setup** - Deploy AlDeci (Demo or Enterprise mode) - Configure evidence sources - Set up evidence retention (7 years) - Configure cryptographic signing

**Deliverables:** - SOC 2 control matrix - Evidence requirements document - AlDeci deployment

#### 1.12.2 9.2 Phase 2: Automation (Weeks 5-8)

**Week 5-6: CI/CD Integration** - Integrate SBOM generation (Syft) - Integrate vulnerability scanning (Grype, Snyk) - Integrate SAST/DAST/SCA (SonarQube, Semgrep) - Push evidence to AlDeci

**Week 7-8: Infrastructure Integration** - Integrate cloud APIs (AWS, Azure, GCP) - Integrate SIEM (Splunk, Datadog) - Integrate IAM (Okta, Azure AD) - Pull evidence from infrastructure

**Deliverables:** - Automated evidence collection for 22+ controls - Weekly evidence bundles - Real-time compliance dashboard

#### 1.12.3 9.3 Phase 3: Validation (Weeks 9-12)

**Week 9-10: Evidence Validation** - Review evidence completeness - Verify evidence signatures - Test evidence retrieval - Identify and fill evidence gaps

**Week 11-12: Audit Preparation** - Generate audit evidence package - Create control matrix - Prepare auditor portal - Conduct internal audit

**Deliverables:** - Complete evidence package (12 months) - Audit-ready status - Auditor portal access

#### **1.12.4 9.4 Ongoing: Continuous Compliance**

**Daily:** - Automated evidence collection - Real-time monitoring - Alert on evidence gaps

**Weekly:** - Review compliance dashboard - Address evidence gaps - Update control matrix

**Monthly:** - Generate compliance reports - Review MTTR trends - Optimize evidence collection

**Quarterly:** - Internal audit - Update policies and procedures - Review and improve automation

---

**DevOps.ai** | Sydney, Australia | <https://devops.ai> | [contact@devops.ai](mailto:contact@devops.ai)

© 2025 DevOps.ai. All rights reserved.